CGU · AFFC · TI – Desenvolvimento de Sistemas · Cebraspe · Edital 1/2026

Aula 1
Ataques a aplicações web

Injeção (SQL e LDAP), XSS, CSRF, negação de serviço (DDoS) e o OWASP Top 10

Seção do edital

P3 · Desenvolvimento seguro, qualidade e gestão da entrega — item 1: Segurança de aplicações (1.1 Ameaças e vulnerabilidades em aplicações e interfaces; 1.2 Validação de entradas e controles de acesso; 1.3 Dependências).

Por que esta aula primeiro

Foi montada de trás para frente, a partir de itens reais do Cebraspe (TCE-AC 2024). Os temas desta aula concentram a maior parte da "massa" de itens já mapeados na seção: CSRF, DDoS, LDAP injection, XSS e SQL injection.

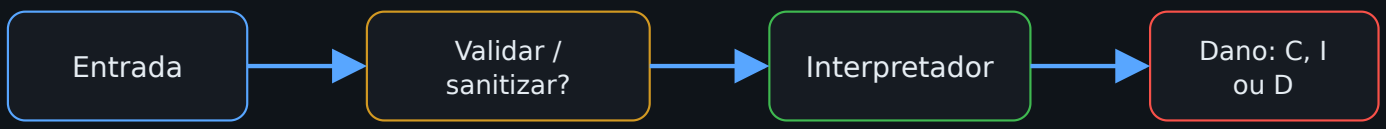
Base: 43 itens reais classificados nesta seção; 18 deles passaram em dupla verificação independente. O caderno final usa só itens reais, com link da prova oficial no CDN do Cebraspe.

1. Objetivo e mapa da aula

Ao final você deve conseguir olhar um item Certo/Errado sobre ataques web e responder: **qual ataque é esse, quem é a vítima, o que ele quebra (confidencialidade, integridade ou disponibilidade) e qual defesa realmente funciona**.

Bloco	Pergunta que ele responde	Palavra-chave da prova
A. Ideia central	Por que existem ataques de injeção?	dado tratado como comando
B. SQL e LDAP injection	Quem é atacado? Como se previne?	validação / sanitização de entrada
C. XSS	O alvo é o servidor ou o usuário?	usuário / navegador
D. CSRF	O que o atacante precisa que a vítima tenha?	sessão autenticada ativa
E. DoS × DDoS	O que é perdido? Firewall resolve?	disponibilidade / distribuído
F. OWASP Top 10	Quais categorias a banca mistura?	controle de acesso, componentes, XXE

Linha do raciocínio



Quase tudo desta aula é uma entrada que passou sem filtro e foi interpretada por alguém (banco, diretório, navegador).

2. Do zero: como uma página web funciona

Analogia: um restaurante. O cliente (navegador) entrega um pedido (requisição) ao garçom (servidor web). O garçom leva à cozinha (banco de dados) e traz o prato (resposta). Para não pedir a senha a cada prato, o restaurante dá uma **pulseira** ao cliente que entrou: é a **sessão** (normalmente um cookie). Quem tem a pulseira é tratado como o cliente autenticado.

- **Requisição:** o que o navegador envia (endereço, campos de formulário).
- **Resposta:** o que o servidor devolve (HTML, que o navegador executa).
- **Sessão/cookie:** a pulseira que prova "já me autentiquei".

> **Duas regras que explicam tudo**
> 1) Se o servidor monta um comando juntando texto vindo do usuário, o usuário pode escrever o comando. (**injeção**) 2) Se o navegador executa o que o site devolve, e o site devolveu texto do usuário, o usuário pode escrever um programa. (**XSS**) Além disso, o navegador envia a pulseira sozinho a cada pedido ao site, e isso permite o **CSRF**.

3. Injeção: SQL e LDAP

3.1 Construindo o raciocínio com exemplos crescentes

Exemplo 1 – o formulário honesto. Um login monta a consulta juntando o que foi digitado:

```
"SELECT * FROM usuarios WHERE nome='" + nome + "' AND senha='" + senha + "'"
```

Se o nome for `ana` e a senha `123`, o banco recebe: `... nome='ana' AND senha='123'`. Funciona.

Exemplo 2 – o texto que parece comando. E se o campo nome for `ana'--`? O texto vira:

```
... WHERE nome='ana'--' AND senha=''
```

As aspas fecham o texto e `--` comenta o resto: a verificação da senha desaparece. A entrada deixou de ser **dado** e virou **comando**.

Exemplo 3 – o mesmo problema, outro alvo. Um diretório (LDAP) é uma "lista telefônica" corporativa. A busca monta um filtro como `(&(uid=ana)(senha=123))`. Inserindo caracteres especiais do filtro, o atacante muda o sentido da busca. Isso é **LDAP injection**: *manipular as consultas LDAP, inserindo código malicioso que é interpretado de forma diferente do esperado*.

> **Conclusão deduzida**
> SQL injection e LDAP injection são o mesmo defeito (entrada sem validação/sanitização) aplicado a interpretadores diferentes. Por isso a banca os agrupa como **ataques de injeção de código**, junto com XSS.

3.2 Defesas (o que a banca trata como correto)

Defesa	Ideia
Validar a entrada com lista de permissão	Aceitar só o formato esperado (ex.: só dígitos num campo numérico).
Consultas parametrizadas	O comando e os dados seguem por canais separados; o dado nunca vira comando.
Privilégio mínimo no banco	Mesmo com falha, o dano é menor.
Frameworks que validam	Ajudam, mas **não dispensam testes** automatizados e manuais.

> **Pegadinha clássica**
> "O uso de framework que valida injeção dispensa testes" → **Errado**. Palavra de alerta: *dispensa*.

4. XSS (Cross-Site Scripting)

Ideia: o atacante coloca um script em um lugar que o site depois mostra a **outras pessoas**. O navegador da vítima executa o script achando que veio do site confiável. O alvo direto é o **usuário**, não o servidor nem o banco.

Tipo	Como o script chega

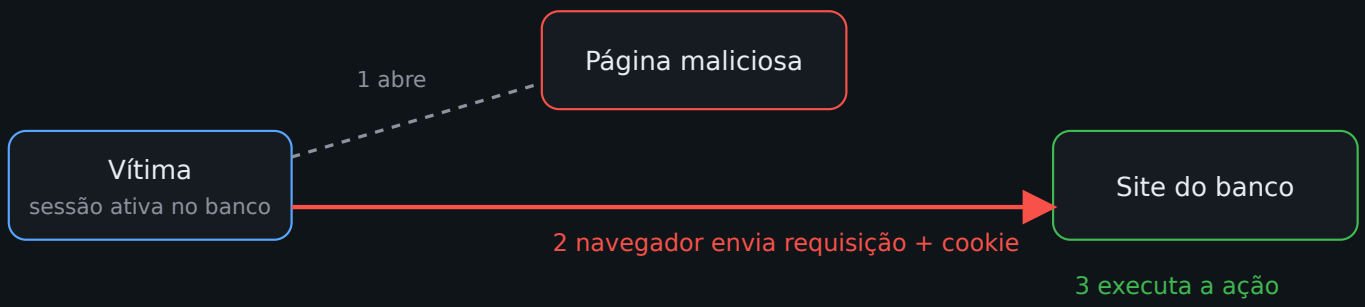
Refletido (não persistente)	Vai na requisição e volta na resposta HTTP; a vítima é induzida a clicar num link.
Armazenado (persistente)	Fica gravado no site (comentário, perfil) e atinge quem abrir.
Baseado em DOM	O próprio script da página manipula o conteúdo do lado do cliente.

> **Confusão provocada pela banca**
> XSS explorando "como o banco de dados executa consultas" → isso é a definição de **SQL injection**. Troca de definição = **Errado**.

5. CSRF (Cross-Site Request Forgery)

Voltando ao restaurante: o cliente está dentro com a pulseira. Um golpista deixa um bilhete ("transfira R$ 100") no caminho dele, e o garçom, ao ver a pulseira, obedece. A vítima **nunca decidiu** aquela ação.

Passo a passo: (1) a vítima está autenticada no site do banco; (2) abre outra página maliciosa; (3) essa página faz o navegador enviar uma requisição ao banco; (4) o navegador anexa o cookie sozinho; (5) o banco executa. Definição da banca: *induz o usuário a usar, sem querer, suas credenciais/sessão para invocar uma ação indesejada*.



> **Pegadinha real (TCE-AC 2024)**
> "Para o CSRF funcionar, *basta* que a vítima tenha conectado *em algum momento* sua conta" → **Errado**. É preciso a sessão/credencial **válida no momento** do ataque. Padrões: *basta* (absoluto) + omissão da condição.

XSS × CSRF em uma tabela

	XSS	CSRF
O que o atacante explora	Confiança do usuário no site	Confiança do site no navegador do usuário
Executa script na vítima?	Sim	Não necessariamente: só força um pedido
Precisa de sessão ativa?	Não obrigatoriamente	Sim
Alvo direto	Usuário	Ação feita em nome do usuário

6. Negação de serviço: DoS e DDoS

Analogia: uma loja. DoS = uma pessoa fica parada na porta e impede a entrada. DDoS = mil pessoas, vindas de lugares diferentes, lotam a porta. Não é mais possível bloquear "aquela pessoa".



O que o DDoS atinge e como se defende

- **Pilar afetado: disponibilidade** (o serviço fica fora do ar). Não é integridade nem confidencialidade. A banca troca o pilar: "perda de integralidade dos dados" → **Errado**.
- **Volumétrico:** enche o link de tráfego. Também há ataques de camada de aplicação, que parecem usuários legítimos.
- **Amplificação/reflexão:** o atacante usa servidores de terceiros (por exemplo, DNS) para multiplicar o tráfego. **Envenenamento de cache DNS** pode estar associado a esses ataques.
- **Mitigação:** exige soluções específicas (filtragem de tráfego, serviços anti-DDoS, CDN, limitação de taxa, escala). **Um firewall de borda sozinho não basta**, e antivírus não resolve.

> **Pegadinhas reais**
> • "DoS e DDoS usam *apenas um* computador... *apenas* um antivírus" → Errado (confunde DoS com DDoS + absoluto).
> • "Firewall de borda mitiga DDoS de maneira *eficiente*" → Errado (ignora a camada de aplicação).

7. OWASP Top 10: o que a banca mistura

O OWASP Top 10 é uma lista de **categorias de riscos** mais críticos em aplicações web. A banca costuma pegar uma categoria e trocar sua causa ou seu exemplo por outra.

Categoria	Em uma frase	Troca típica da banca
Quebra de controle de acesso	Usuário autenticado consegue fazer o que não deveria (acessar dado de outro, executar função de admin).	Chamar de "ataque que analisa entrada XML" (isso é **XXE**).
Componentes vulneráveis/desatualizados	Usar biblioteca com falha conhecida e sem atualização.	Dizer que "resulta da desserialização" (é outra categoria).
Desserialização insegura	Aceitar objetos serializados de fonte não confiável.	Misturar com componentes.
XXE (entidades externas de XML)	Parser XML processa entidades externas e expõe dados/recursos.	Chamar de "controle ou boa prática".
Falhas de log e monitoramento	Registrar falhas de login/acesso com contexto e reter por tempo suficiente.	Pedir "logs mínimos" ou sem retenção.

> **Cuidado com versões**
> A lista foi reorganizada entre edições (por exemplo, XXE e desserialização aparecem de forma diferente de uma edição para outra). Em prova, apoie-se no enunciado: a banca cobra a **definição da categoria**, não a numeração. Confirme a edição da lista no documento oficial do OWASP ao revisar.

8. Como a banca cobra (padrões)

Padrão	Exemplo de redação	Veredito
Troca de definição	"XSS explora a execução de consultas do banco"	**Errado**
Troca de pilar (CIA)	"DDoS causa perda de integridade"	**Errado**
Absoluto	"basta…", "apenas…", "dispensa…", "somente…"	**quase sempre Errado**
Condição omitida	CSRF "em algum momento" conectado	**Errado**
Definição limpa	"LDAP injection manipula consultas LDAP inserindo código"	**Certo**
Classificação correta	"SQLi, LDAPi e XSS são injeções de código"	**Certo**

9. Técnica para a prova Certo/Errado

- **Errar desconta o mesmo que acertar.** Se o item está fora do seu domínio e você não consegue separar em partes, deixar em branco vale 0; um chute vale esperança 0 quando você acerta 50%.
- **Separe o item em duas metades:** (sujeito) + (afirmação). Nos itens desta aula, o erro quase sempre está numa das metades: o sujeito (qual ataque) ou o pilar (C, I ou D).
- **Sublinhe palavras absolutas:** basta, apenas, somente, nunca, sempre, dispensa, qualquer.
- **Itens de definição curta e sem absoluto** costumam ser Certos (o examinador reaproveita o conceito certo). Nesta aula: LDAP injection, CSRF e SQLi definidos corretamente apareceram como Certos.
- **Quando arriscar:** se você eliminou o erro de definição e de pilar e sobrou dúvida pequena, arrisque. Se tem dúvida na definição, deixe em branco.

10. Resumo de revisão (na ponta da língua)

- Injeção = entrada sem validação/sanitização interpretada como comando. SQL, LDAP e XSS são injeções de código.
- SQLi: alvo = banco. LDAP injection: alvo = consulta ao diretório. XSS: alvo = **usuário/navegador**.
- Defesa de injeção: validação por lista de permissão + consultas parametrizadas. Framework **não dispensa testes**.
- XSS: refletido (volta na resposta), armazenado, DOM.
- CSRF: ação indesejada com a **sessão ativa** da vítima. "Basta ter conectado alguma vez" = Errado.
- DoS = uma origem; DDoS = várias. Afeta **disponibilidade**. Firewall de borda e antivírus sozinhos não bastam.
- OWASP: não misture quebra de controle de acesso, XXE, desserialização e componentes vulneráveis.

Caderno de questões – Aula 1

10 itens reais do Cebraspe (TCE-AC 2024). Julgue Certo ou Errado; o gabarito comentado vem depois. Cada item traz tema, nível, referência e a URL da prova oficial (PDF do CDN do Cebraspe); o gabarito definitivo está na URL indicada em "gab.".

1 Injeção › LDAP fácil

O objetivo do ataque de LDAP injection é manipular as consultas LDAP, por meio da inserção de um código malicioso na consulta, que passa a ser interpretado de forma diferente do esperado.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 8 (Analista de TI – Planejamento de TI) · item 87
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_008_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_008_01.PDF

2 XSS fácil

XSS (Cross-site scripting) é um método pelo qual um invasor explora vulnerabilidades na maneira como um banco de dados executa consultas de pesquisa.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 8 (Analista de TI – Planejamento de TI) · item 88
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_008_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_008_01.PDF

3 CSRF fácil

Um ataque de cross-site request forgery é aquele que induz um usuário a usar acidentalmente suas credenciais para invocar uma ação indesejada.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 8 (Analista de TI – Planejamento de TI) · item 89
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_008_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_008_01.PDF

4 OWASP › componentes médio

O uso de componentes com vulnerabilidades conhecidas é uma das categorias de riscos de segurança do OWASP Top 10 que resulta da desserialização de dados de fontes não confiáveis.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 8 (Analista de TI – Planejamento de TI) · item 91
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_008_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_008_01.PDF

5 DDoS › mitigação médio

Um firewall de borda é considerado como o elemento capaz de fazer a mitigação de ataques DDoS de maneira eficiente, já que o tráfego da camada de aplicação tem que ser bloqueado na entrada da rede.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 8 (Analista de TI – Planejamento de TI) · item 93
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_008_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_008_01.PDF

6 SQL injection fácil

Em função de muitos sites e aplicativos da Web dependerem de bancos de dados SQL, um ataque SQL injection pode gerar sérias consequências, porque boa parte dos formulários da Web não consegue impedir a entrada de informações adicionais, o que propicia a exploração desse ponto fraco e o uso das caixas de entrada no formulário para envio de solicitações maliciosas ao banco de dados.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 20 (Técnico de Controle Externo – Informática) · item 92
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_020_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_020_01.PDF

7 CSRF médio

Para que um ataque de cross-site request forgery funcione em aplicações web, basta que a vítima tenha conectado, em algum momento, sua conta original ao disparar a requisição maliciosa.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 20 (Técnico de Controle Externo – Informática) · item 90
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_020_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_020_01.PDF

8 XSS médio

Um ataque de XSS (cross-site scripting) não tem como alvo direto o próprio aplicativo, mas sim os usuários do aplicativo da Web.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 20 (Técnico de Controle Externo – Informática) · item 94
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_020_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_020_01.PDF

9 DoS × DDoS fácil

Os ataques de DoS e DDoS utilizam apenas um único computador para sobrecarregar um servidor de rede, tornando-o indisponível, sendo necessário apenas um software antivírus para prevenir e combater esses ataques.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 20 (Técnico de Controle Externo – Informática) · item 113
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_020_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_020_01.PDF

10 OWASP › controle de acesso médio

Entre os riscos de segurança incluídos no relatório OWASP Top 10, a quebra de controle de acesso é um ataque contra um aplicativo web que analisa a entrada XML.

Ref.: Cebraspe · TCE-AC · 2024 · Cargo 11 (Analista de TI – Sistemas de Informação) · item 105
Prova: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/993_TCE_AC_011_01.PDF
Gab.: https://cdn.cebraspe.org.br/concursos/TCE_AC_24/arquivos/GAB_DEFINITIVO_993_TCE_AC_011_01.PDF

Gabarito comentado

Item	Gab.	Comentário (estilo Cebraspe)
1	**Certo**	Definição correta de LDAP injection: manipulação da consulta ao diretório por código inserido na entrada.
2	**Errado**	Troca de definição: explorar a execução de consultas do banco é **SQL injection**. O XSS mira o navegador do usuário.
3	**Certo**	CSRF faz o usuário (sem perceber) usar sua sessão/credencial para uma ação indesejada.
4	**Errado**	Mistura de categorias: componentes vulneráveis não "resultam da desserialização"; a desserialização insegura é outro risco. Padrão: causa/consequência trocada.
5	**Errado**	Firewall de borda não mitiga DDoS de forma eficiente, pois há ataques de camada de aplicação e volumétricos; exige soluções específicas.
6	**Certo**	Descrição correta: a falha está na entrada sem validação/sanitização, que chega ao banco.
7	**Errado**	"Basta... em algum momento": falta a condição de **sessão válida no momento do ataque**. Absoluto + omissão.
8	**Certo**	No XSS o alvo direto é o usuário (o app é o veículo).
9	**Errado**	DDoS é distribuído (várias origens); antivírus não é solução única. Absoluto ("apenas") e conceito misturado.
10	**Errado**	Quebra de controle de acesso é falha de restrições sobre o que usuários autenticados podem fazer. O ataque que analisa entrada XML é o **XXE**.

Contagem de gabarito

Certos: 1, 3, 6, 8. Errados: 2, 4, 5, 7, 9, 10. Os gabaritos são os definitivos do Cebraspe, conforme registrados no banco.

Fontes

Itens: provas do Cebraspe/TCE-AC 2024 (CDN oficial). Conceitos: OWASP Top 10 e documentação OWASP sobre injection, XSS e CSRF; definições usadas apenas para ensino.